
Cloud Security Quick-Start

The 10 things to do before your first AWS or Azure deploy.

A 1-page checklist by Kerry P. — Cloud, DevOps & Security Engineer · Instructor at CyberTex Institute · Austin, TX

IDENTITY

- 01. Turn on MFA for the root / global admin account first.** Then never log in as root again. Create a personal admin user, hand the root password to a password manager, and walk away.
- 02. One human, one identity.** No shared logins. Real names map to real accountability. Programmatic work uses a service principal / IAM role — never a human user's keys.
- 03. Block long-lived access keys.** Use STS / federated identity / managed identities. If a key has to exist, scope it tight and rotate it.

NETWORK

- 04. Private by default.** New resources land in a private subnet. Public exposure is a deliberate decision with a written reason.
- 05. No 0.0.0.0/0 on management ports.** SSH, RDP, database ports — never open to the internet. Tunnel through SSM / Bastion / VPN.

DATA

- 06. Encrypt at rest, everywhere.** Default on the storage service. If you have to enable it manually, you're using something old.
- 07. Block public buckets unless you can name the file.** S3 Block Public Access + Azure "no anonymous" — at the account level.

VISIBILITY

- 08. Turn on logging before you need it.** CloudTrail / Activity Log / VPC Flow Logs / NSG flow logs. Aggregate to one place. You can't investigate what you didn't record.
- 09. Alert on root login, IAM changes, and security-group edits.** Three alerts catch most of the noisy stuff.

RECOVERY

- 10. One backup that isn't in the same account.** Cross-account or cross-region copy. The blast radius of a compromised account should not include your backups.

What this is for. This is the floor — not the ceiling. If you do these ten things you're ahead of most teams shipping their first cloud workload. After this, the conversation gets specific to your stack: compliance scope, IaC standards, secrets management, container hardening, observability.

If you want help going further, that's what I do. Reply to the email this came with, or visit akplearner.github.io/#connect to book a 20-minute briefing.

— Kerry